A3-PS024-TC021

Privacy Pass Token Issuance and Anti-Replay Gateway

Team: Navam

Adona Mariya Salu
adona.mariya@btech.christuniversity.in

Joy Aanchal Rose
joy.aanchal@btech.christuniversity.in

AIORI Hackathon 3

October 14, 2026

Problem Description

Services need abuse prevention without building linkable identity trails.

Privacy Pass lets a client prove eligibility once and later redeem a token anonymously. The challenge is to integrate this flow into a lab issuer, client and verification gateway while enforcing one-time use.

- Issue a valid Privacy Pass token using one supported RFC 9578 protocol
- Verify tokens at a gateway without linking redemption back to issuance
- Reject replayed, invalid and wrong-context tokens with clear test evidence
- Measure issuance and redemption latency for the prototype demo
- Document metadata retained by the issuer, client and gateway

Background

Privacy Pass separates eligibility from access by using blinded tokens.

Problem: Many services need abuse control, but ordinary login or IP checks create linkable identity traces.

Privacy Pass: The issuer validates a client once and signs a blinded token. The verifier later checks it without seeing the issuance event.

Anti-replay: The gateway stores only redemption fingerprints and context rules, then rejects reused or wrong-context tokens. [1]

Why this matters in a lab demo

- Judges can test every branch: issue, redeem, replay, invalid token and wrong context
- Privacy assumptions become evidence rather than hidden details
- The gateway gives mentors a concrete place to inspect cost, latency and retained metadata

Literature & RFC Review

The project uses the standards as constraints instead of inventing cryptography. [1], [2]

Reference	What it contributes	How it shapes the prototype
RFC 9576 [1]	Privacy Pass architecture	Defines issuer, client, verifier and unlinkability assumptions
RFC 9578 [2]	Issuance protocol	Guides the supported token issuance flow
Replay-cache practice	Single redemption enforcement	Stores token fingerprints and expiry, not user identity
Threat modeling	Metadata and trust boundaries	Documents what issuer, client and gateway can still observe

ARC is treated only as an optional, separate extension. No new cryptography is introduced.

Proposed Solution

A controlled Privacy Pass pipeline with replay evidence and privacy analysis.

1 Lab issuer	Implements the selected RFC 9578 issuance protocol and keeps isolated signing keys.
2 Client module	Requests, unblinds, stores and redeems one token for a protected action.
3 Verification gateway	Validates token proof, request context, origin key and replay status.
4 ReplayLab console	Runs valid, replayed, invalid and wrong-context cases with latency and metadata output.

Flow: the issuer grants a blinded token after controlled eligibility checks, the client unblinds and stores it, the gateway validates it, checks context and consults the replay cache, and the console records every scenario.

Optimization Proposed

Before and after comparison of the proposed enhancements.

Scenario	Before optimization	After optimization	Expected improvement
Token replay	No structured replay check	Replay cache stores redemption fingerprint with TTL	Single redemption is enforced
Wrong-context use	Token not bound to request context	Gateway checks context, origin key and protected action	Misused tokens are rejected
Privacy review	Metadata analysis is manual and incomplete	Component-wise retention checklist	Unlinkability assumptions are visible
Demo evidence	Terminal logs hard to verify	ReplayLab console runs all cases and records latency	Demo becomes repeatable

Optimization goal: improve proof quality without changing the cryptographic protocol or claiming new cryptography.

Solution Architecture & Design

Flowchart showing the optimized token issuance and anti-replay process.

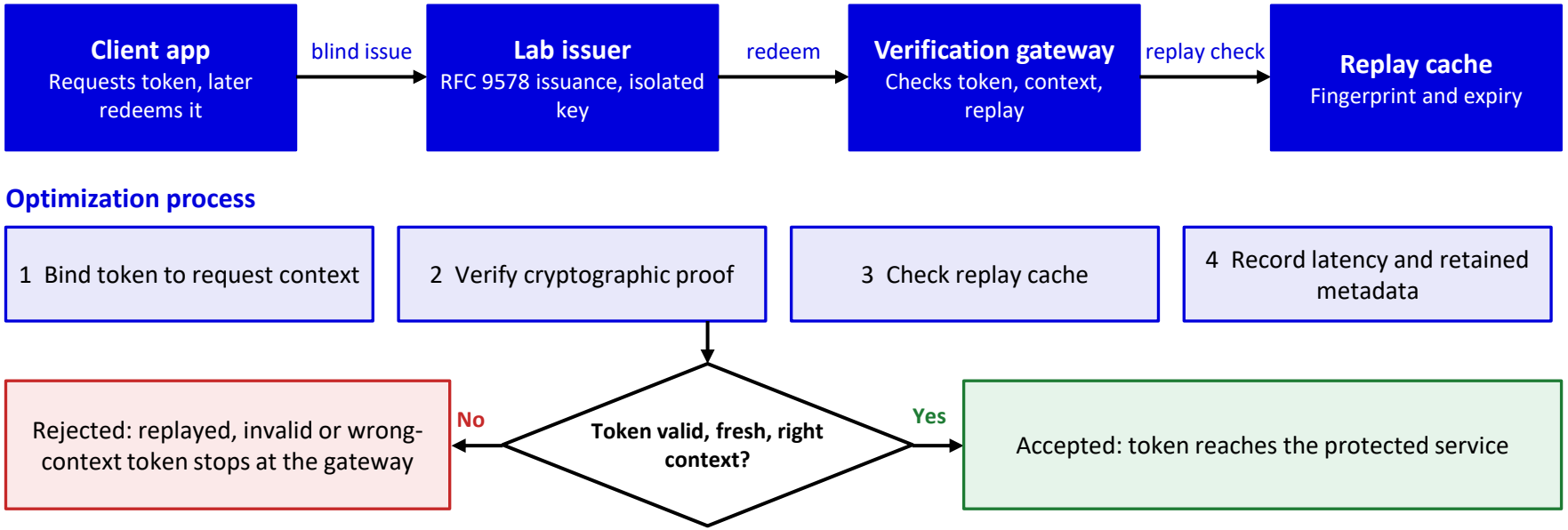
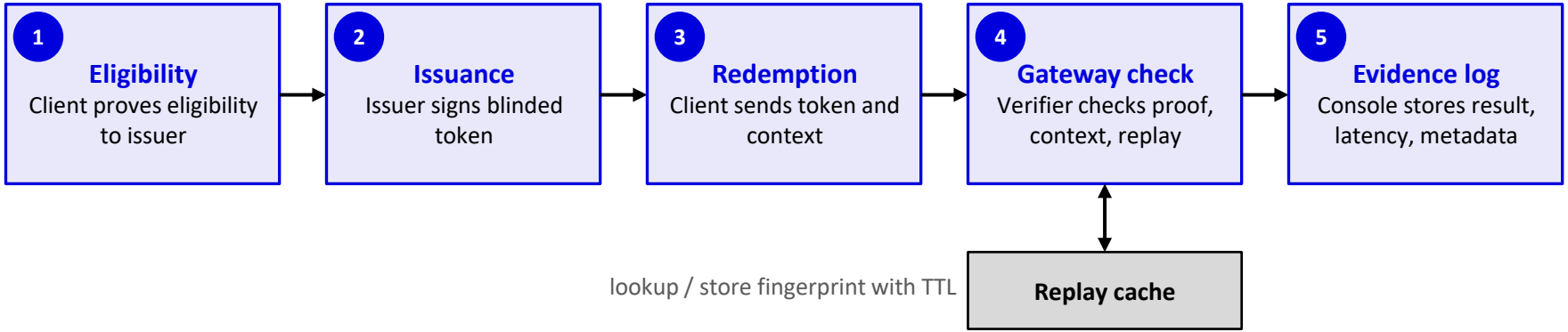


Figure: System architecture and anti-replay flow

Data Flow Diagram

Issuance, redemption, replay check and evidence logging, following the flowchart on the previous slide.



Valid token path
A fresh token passes cryptographic validation, context validation and replay-cache lookup. The gateway allows the protected action.

Rejected token path
A reused, invalid or wrong-context token fails before reaching the protected service. The console records the reason.

Figure: Data Flow Diagram (DFD)

Deployment Timeline

Milestones and methodology for building the prototype.

Phase	Milestone	Key activities
Phase 1	Setup and study	Create private GitHub repo, assign roles, review RFC 9576 and RFC 9578, select library
Phase 2	Core implementation	Build issuer, client, verification gateway and isolated key configuration
Phase 3	Anti-replay layer	Add replay cache, request-context validation, origin key checks and rejection responses
Phase 4	Testing and metrics	Run valid, replayed, invalid and wrong-context cases with latency measurement
Phase 5	Final demo package	Prepare demo script, screenshots, metadata-retention table and mentor-ready repository

Methodology: iterative prototype development with daily component integration, scenario testing and evidence capture after every milestone.

Bibliography

[1] A. Davidson et al. “The Privacy Pass Architecture.” RFC 9576, RFC Editor (2024).

[2] A. Davidson et al. “Privacy Pass Issuance Protocols.” RFC 9578, RFC Editor (2024).

[3] AIORI Hackathon 3. “PS-024: Privacy Pass Token Issuance and Anti-Replay Gateway.” Problem statement (2026).

[4] Privacy Pass Working Group documentation and notes for the selected library.

[5] Project repository and demo evidence: [add GitHub link after repository transfer].

Thank You for Your Attention!